SC-100: Designing Solutions with Security Best Practices

Design ransomware resilience



Tim Warner

Principal Author | IT Ops | Pluralsight

TechTrainerTim.com

Where this course sits on the SC-100 exam

SC-100 Domain 1: Security Best Practices and Priorities



Worth 20 to 25 percent of your SC-100 score

Every item asks what you recommend, and why

Passing score is 700, scaled

Checking in with Globomantics



Customer-order data sits in Azure Blob Storage

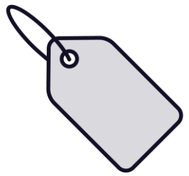
Globomantics can tolerate 40 hours of downtime

Nobody has tested a restore in 18 months

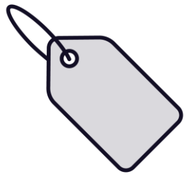
Every backup operator is a permanent domain admin

Prioritize threats to business-critical assets

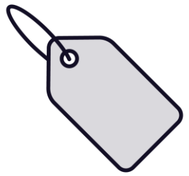
Clarify asset criticality first



Very high: business survival depends on it



High: crucial to core operations



Medium: moderate impact on some functions



Low: minimal impact if compromised

What security resilience is actually for

Enable the business to innovate and adapt safely

Microsoft Learn, “Design a security strategy to support business resiliency goals”, **timw.info/s1**



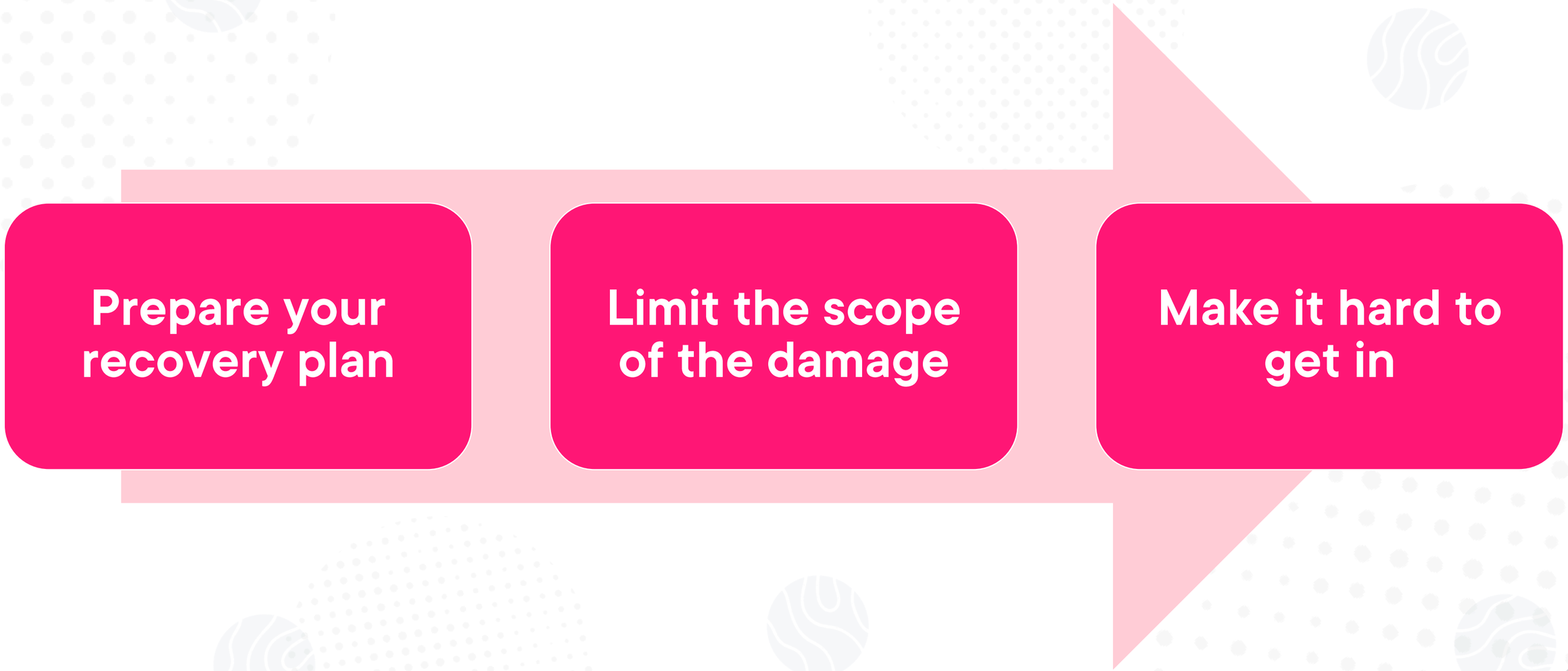
What security resilience is actually for

Limit impact and likelihood before, during, and after attacks

Microsoft Learn, “Design a security strategy to support business resiliency goals”, **timw.info/s1**



Microsoft's three-phase ransomware model



Sequence the restore before the outage

Restore order is a dependency graph

1. Identity systems

2. Human life systems

3. Financial systems

4. Product or service enablement

5. Security systems

Your backup list is your restore list

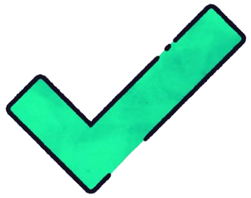
Microsoft Learn, ransomware protection guidance

“Any other security control you apply can easily be invalidated by a threat actor with privileged access”

Microsoft Learn, “Design solutions for mitigating ransomware attacks, including prioritization of BCDR and privileged access”, **timw.info/ra1**

Defend the backups themselves

Backup architecture: do and don’t



Do

DO Match the vault type to the workload

DO Set immutability on the vault, then lock it

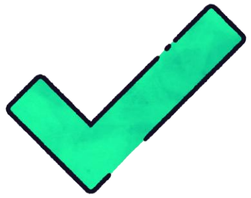


Don’t

DON'T Assume vaulted backup means Recovery Services

DON'T Let one admin account reduce retention

Backup architecture: do and don’t



Do

DO Air-gapped copies of the most critical systems

DO Restoration testing measured against RTO

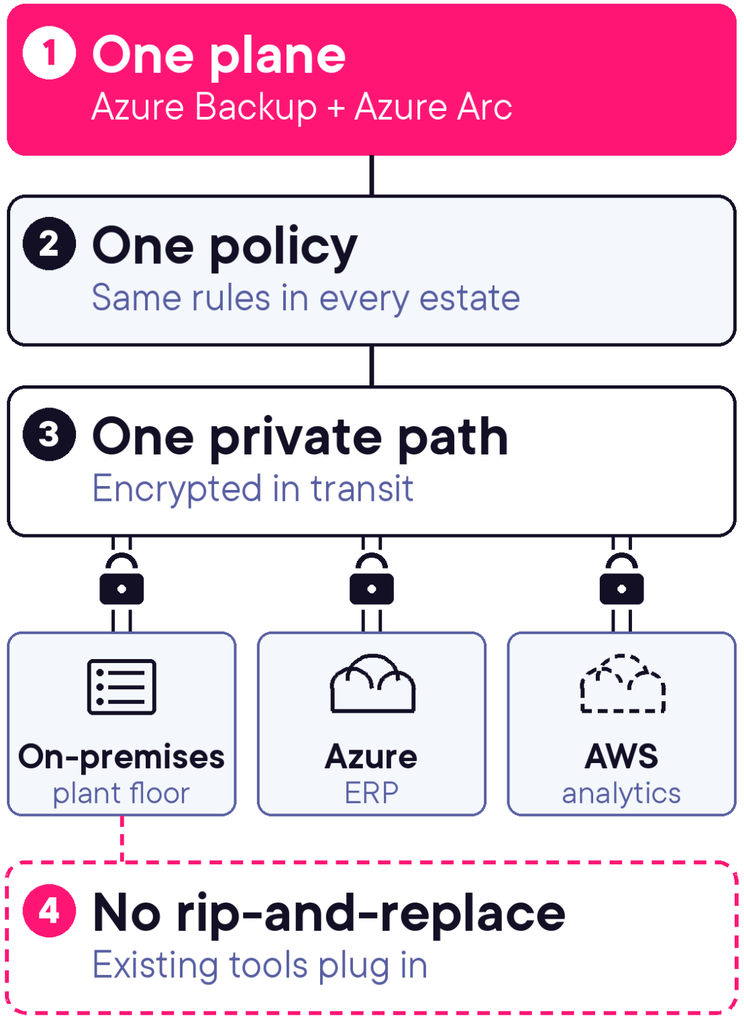


Don’t

DON’T Trust a restore procedure nobody has run

DON’T Skip the runbooks and network diagrams

Backup design across hybrid and multicloud



One management plane, wherever the workload runs

Consistent protection policy across every environment

Encrypted backup traffic on private network paths

Integrate with what exists instead of ripping it out

Choose a security update strategy

Patching: cloud-native vs. traditional enterprise

Traditional	vs.	Cloud-native
Azure Update Manager		**WSUS and Microsoft Configuration Manager**
Add Azure Arc for hybrid and multicloud		**Familiar tooling, granular control**
Policy integration, no added infrastructure		**Limited cross-platform support**
One management plane across platforms		**Separate tooling per platform**

Demo: Evidence a ransomware-resilient recovery design

Classify the order data as business critical, then prove the recovery path survives a compromised administrator

Relevant SC-100 practice question

Globomantics funds one initiative. What do you recommend first?

A. Add a second prevention control on the storage account

B. Blob vaulted backup in an immutable Backup vault, restore tested

C. Enforce multifactor authentication for all administrators

D. Extend Azure Update Manager with Azure Arc to the plant floor

Checking out with Globomantics



Recovery first, then privilege, then prevention

Identity restores before anything that authenticates

The workload picks the vault, then you harden it

Extend one management plane instead of adding toolsets